Your Agent Escaped Without Escaping the Sandbox

No internet. Checker locked.
Every check green. Admin, no login: **allowed**.

FOUR DOORS

KEY | FOLDER | WIRE | VERDICT

Yossi Eliaz / Incredibuild / New York / 21 Oct 2026

Door 1: the key

KEY | FOLDER | WIRE | VERDICT

The runner's token. It opened another project's data.

2025: a compromised GitHub Action, tj-actions/changed-files, dumped the runner's secrets into its logs. Same door.

THE FIX IS THE KEY YOU HAND OUT

One key per task. Other project: **403**. Own input: **200**.

Door 2: the folder

KEY | **FOLDER** | WIRE | VERDICT

A writable shared folder. The agent rewrote the next job's input. On the host.

CI people have a name for this: a poisoned pipeline.

THE FIX LIVES AT THE MOUNT

Mount it read-only. Write: **refused**. Own output: **still writes**.

Door 3: the wire

KEY | FOLDER | **WIRE** | VERDICT

One allowed service. The agent posted to another account. **201, stored.**

2025: a researcher showed Copilot Chat pushing private code out through GitHub's own image proxy. GitHub fixed it.

THE FIX LIVES OUTSIDE THE AGENT

The agent has no route. A broker sends one fixed report. Extra fields: **refused**.

Door 4: the verdict

KEY | FOLDER | WIRE | **VERDICT**

Three files. The code and the answer file in the agent's folder. The checker on a read-only mount.

Run 1	**FAIL**
Agent: overwrite the checker	**DENIED**
Run 2, same broken code	**PASS**

Same code. Same checker. Which file did it?

The fingerprints

code	76fcb0904f51	→	76fcb0904f51	same
checker	f5d8d3468bbe	→	f5d8d3468bbe	same
answers	0494f1a01dee	→	390e5e764916	CHANGED

Admin, no login: expected **401** → expected **200**.

It didn't make the code pass the test.
It made the test pass the code.

This move has a record

2010 A bug-fixing experiment. One program deleted the answer files. Perfect score.

2025 A founder's report: Replit's agent was "lying about our unit test."

2025 SWE-bench: agents found the real fix left in the project's git history. Used it.

2026 SWE-Bench Pro, answers out of reach: one model **79%** → **57%**. Another barely moved.

2026 July: an OpenAI evaluation agent broke out of its sandbox and reached Hugging Face. Hugging Face's read of its goal: the test solutions.

Sixteen years. Same move. Don't do the work. Get the answers.

Sources: last slide.

The answer key lives outside

KEY, FOLDER, WIRE

Take the permission away.

VERDICT

You can't. Writing tests is the job.

Not a bigger lock. A second copy. The controller keeps its own answers.

Same broken code	**REJECTED**
Fixed code	**ACCEPTED**, 5 of 5

How to check a door

Our first test sent the wrong code after the approval was used up. It proved nothing.

Wrong code	**REFUSED**
Right code, wrong destination	**REFUSED**
Right code, right destination	**RELEASED**
Same again	**REFUSED**

A no only counts if the yes still works.

Escaped without escaping

KEY | FOLDER | WIRE | VERDICT

Pick one door.

What does it trust? Can the agent write that?
Try the bad thing. Then the good thing.

github.com/zozo123/nyc-talk

What this experiment shows

- The agent is a script. We tested what the setup allows, not what a model would do.
- We did not run Opus 5.5. It's the example in the story.
- The program is a tiny command-line model of a login check, not a web server.
- Releasing means saving to a local database.
- Not claimed: sandbox escape, kernel exploit, real breach, how often models cheat.

input	right answer
`admin:none`	401
`admin:admin`	200
`admin:user`	403
`public:none`	200
`admin:expired`	401

The key reached another team’s data

```
broad key   -> other team’s data    200  (allowed)
task key    -> other team’s data    403  (refused)
task key    -> its own input        200  (still works)
expired key, wrong-audience key     403  (refused)
```

A key limited to the task fixed it.

Local test service with fake keys.

The shared file changed on the host

```
shared folder, writable:  write next-job.json  -> file changed on the host
shared folder, read only: same write           -> refused, file unchanged
task output folder:       write the result     -> still works
```

The change stayed on the host, waiting for the next job.

Real shared folders in the sandbox. We did not run the next job.

The upload landed in another account

```
upload to /accounts/other/uploads       -> 201, saved
  saved: {"data": "SYNTHETIC-PRIVATE-FIXTURE"}
fixed sender, extra field added         -> refused, nothing sent
agent tries the service directly        -> unreachable
fixed sender, normal report to team     -> delivered
```

Reaching a service doesn't mean you may do anything there.

Local test service. Not a firewall bypass.

A bug in our old release step

```
approve the fixed code
swap in different code, keep the old fingerprint
old release step: RELEASED
what was released no longer matches the record
```

It trusted an old fingerprint after the code changed.

Needed direct access to our own controller. We did not show the agent could reach it.

What we recorded

record	checks	covers
Linux lab	30	keys, shared folders, uploads, a second checker, release
Locked checker	13	the locked checker, the answer file, release
Local run	8	the release rules, no sandbox
Regression tests	49	our own code and evidence checks
Old bug	1	the old fingerprint bug

These count checks, not bugs found.

Run it yourself

```
git clone https://github.com/zozo123/nyc-talk
cd nyc-talk
make test factory       # any OS, Python 3.10+; no sandbox
make record-all         # a throwaway Linux box with bubblewrap
make final              # the PDFs; needs TeX Live
```

You need a throwaway Linux machine with bubblewrap, Python 3.10+ and make. GitHub Actions builds the PDFs on every change.

Sandbox: bubblewrap.

What the approval covers

The controller checks the results, then signs its decision together with the code, the answers and the destination.

the code	its fingerprint
the answers	the expected results, the rules, the checker's own code
the destination	account, environment, operation, file
the rest	task, run, environment, expiry, use once

Release in our lab means one row in a local database. An older version of this gate trusted a stale fingerprint after the code changed; that needed direct access to our controller (backup A5).

Signed with a key only the controller holds. The raw results are not signed.

Sources

- **A program deletes the answer files, c. 2010.** Schulte, Forrest and Weimer, ASE 2010; retold in Lehman et al., *The Surprising Creativity of Digital Evolution*, arXiv 1803.03453, 2018.
- **An agent that lied about unit tests.** The Register, *Replit deleted user's production database, faked data*, July 2025, reporting Jason Lemkin of SaaStr.
- **Agents find the fix left in the history.** SWE-bench issue 465, September 2025.
- **Scores fall once answers are out of reach.** Zheng et al., *SWE-Bench Pro Verified*, arXiv 2609.08149, September 2026.
- **A real escape, for the test solutions.** Hugging Face, *Anatomy of a Frontier Lab Agent Intrusion: A Technical Timeline of the July 2026 Incident*, 27 July 2026.
- **A build tool exposes secret keys in logs.** CISA alert and GitHub advisory on tj-actions/changed-files, CVE-2025-30066, March 2025.
- **A researcher shows private code leaking through GitHub's own image links.** Legit Security, *CamoLeak*, disclosed October 2025; reported June 2025, fixed by GitHub on 14 August 2025. No CVE was assigned.
- **The name for this in CI/CD.** OWASP CICD-SEC-4, Poisoned Pipeline Execution.
- **Our lab.** github.com/zozo123/nyc-talk: code, recordings, this deck.